

ĐỀ CƯƠNG LUẬN VĂN THẠC SĨ

Họ tên học viên: Nguyễn Huy Hoàng

Giới tính: Nam

Ngày sinh: 30/08/2001

Nơi sinh: Hà Nội

Điện thoại: 0986927523

Email: 23025035@vnu.edu.vn

Cơ quan công tác: Trung tâm bán dẫn Viettel

Cơ sở đào tạo: Trường Đại học Công nghệ, Đại học Quốc gia Hà Nội

Mã học viên: 23025035

Ngành: Công nghệ thông tin

Chuyên ngành: An toàn thông tin

Tên đề tài: Cải tiến structure-aware mutator cho PDF

1. Mục tiêu và ý nghĩa

1.1 Mô tả bài toán

Các coverage-guided fuzzer (AFL/AFL++) rất mạnh với những dữ liệu đầu vào phi cấu trúc (ảnh, âm thanh,...), nhưng gặp hạn chế lớn khi fuzz các định dạng có cấu trúc phức tạp như PDF. Phần lớn dữ liệu đầu vào sau đột biến bị parser loại do sai cấu trúc đầu vào, dẫn đến lãng phí thời gian. Do đó, tôi đề xuất thiết kế một biểu diễn trung gian cho cấu trúc PDF (PDF-IR) cùng tập các thao tác đột biến trên biểu diễn trung gian này để đầu vào sau đột biến vẫn hợp lệ ở mức cú pháp và ngữ nghĩa tối thiểu, nhờ đó tăng hiệu suất, nhanh chóng tìm được lỗi so với các fuzzer khác trong cùng một khoảng thời gian.

1.2 Mục tiêu

- Thiết kế biểu diễn trung gian của PDF để không chỉ đảm bảo cú pháp mà còn mô hình hoá quan hệ ngữ nghĩa cốt lõi của định dạng PDF.
- Thiết kế và triển khai custom-mutator cho PDF dựa trên biểu diễn trung gian của PDF để sinh input có tỉ lệ hợp lệ cao, tăng hiệu suất fuzzing.
- Thiết kế và triển khai plugin custom-mutator cho định dạng PDF chạy trên công cụ fuzzer mã nguồn mở AFL++.
- Chứng minh hiệu quả bằng thực nghiệm, bao gồm: tìm lỗi nhanh hơn (time-to-first-crash thấp hơn) và/hoặc nhiều lỗi hơn, crash unique cao hơn so với các chiến lược đột biến khác có cùng một hệ quy chiếu (cùng fuzzing framework, cùng harness,...).
- Các sản phẩm kèm theo: bản đánh giá chi tiết (kịch bản kiểm thử, biểu đồ thống kê,...), tài liệu hướng dẫn sử dụng, mô tả thuật toán.

1.3 Ý nghĩa

- Tạo ra một biểu diễn trung gian của PDF và bộ đột biến trên biểu diễn đó giúp tăng hiệu suất của fuzzer, phục vụ bảo mật phần mềm.
- Kết quả có tính thực dụng cao do là plugin sử dụng kèm với AFL++.

2. Nội dung của đề tài, các vấn đề cần giải quyết để thực hiện đề tài

2.1. Khảo sát và xác định phạm vi

- Khảo sát các nghiên cứu chiến lược đột biến trong fuzzing cho định dạng PDF, chỉ ra các khoảng trống trong nghiên cứu.
- Lựa chọn target (xpdf, poppler, pdf2svg, pdftium,...)
- Chuẩn bị seed PDF đa dạng

2.2. Thiết kế biểu diễn trung gian PDF

- Xác định danh sách các object, xref, startxref, stream,...trong định dạng pdf bắt buộc phải có, vùng giá trị hợp lệ và các ràng buộc cần có.

2.3. Xây dựng bộ mutator theo cấu trúc PDF

- Nhóm thao tác an toàn (L1): chèn/xoá/thay thế object, nhân bản subtree, tự tạo xref/trailer/startxref
- Nhóm thao tác stream-aware (L2): đổi/hoán chuỗi filter, cập nhật length, chế độ near-valid (có ý làm sai lệnh nhỏ nhưng có kiểm soát kèm thay đổi các trường sao cho định dạng hợp lệ)
- Nhóm thao tác incremental update (L3): thêm nội dung vào body, thêm xref/trailer mới nhưng vẫn cập nhật các trường liên quan để đảm bảo định dạng vẫn hợp lệ

2.4. Tích hợp với AFL++ và tối ưu

- Sử dụng AFL++ custom mutator API, hỗ trợ persistent mode để giữ tốc độ
- Sử dụng tính năng CmpLog của AFL++ để sử dụng thông tin so sánh tại runtime để nhắm vào các keyword như obj, endobj, length, filter,...tăng hiệu suất fuzzing

2.5. Thiết kế và thực hiện thực nghiệm

- Baseline: So sánh với các phương pháp đột biến khác như AFLSmart, pFuzzer, Superion,...cho định dạng pdf
- Metrics: time-to-first-crash, số unique crash, edge/branch coverage, exec/sec, tỷ lệ input hợp lệ
- Kịch bản: mỗi target chạy trong vòng 24-48 tiếng, lặp từ 3 lần trở lên, bật tắt L1/L2/L3, CmpLog để hiểu đóng góp của từng phần

2.6. Triage và báo cáo

- Tái hiện lại crash, chọn 1-2 trường hợp tiêu biểu mô tả ngắn gọn (stacktrace, nguyên nhân)
- Tổng hợp bảng số liệu, biểu đồ, so sánh với baseline, thảo luận ưu/nhược điểm và hướng mở rộng.

3. Dự kiến kế hoạch thực hiện:

STT	Nội dung công việc	Thời gian thực hiện
1	Hoàn thiện đề cương: xác định phạm vi, xác định vấn đề, mục tiêu, phạm vi, kế hoạch và tiêu chí đánh giá	14 ngày
2	Thu thập và tối ưu seed corpus	7 ngày
3	Dựng baseline AFL++ cho 2 target, build target với chế độ build asan, sử dụng AFL++ persistent mode, bộ seed đa dạng	14 ngày
4	Thiết kế biểu diễn trung gian của PDF và các ràng buộc.	21 ngày
5	Thiết kế và triển khai nhóm thao tác an toàn (mutator L1), bao gồm: chèn/xoá/thay thế object, nhân bản subtree, tự tạo xref/trailer/startxref	21 ngày
6	Thiết kế và triển khai nhóm thao tác stream-aware (mutator L2), bao gồm: đổi/hoán chuỗi filter, cập nhật length, chế độ near-valid (cố ý làm sai lệnh nhỏ nhưng có kiểm soát)	21 ngày
7	Thiết kế và triển khai nhóm thao tác incremental update (mutator L3), bao gồm: thêm nội dung vào body, thêm xref/trailer mới	21 ngày
8	Tích hợp với custom mutator API của AFL++	14 ngày
9	Tích hợp với CmpLog trong AFL++ để tăng hiệu suất	14 ngày
10	Thực nghiệm chính (thực hiện fuzzing tối thiểu 2 target trong 24-48h, lặp lại tối thiểu 3 lần, lấy giá trị trung bình), thu coverage, exec/sec, crash	30 ngày
11	Tái tạo và mô tả lại 1-2 lỗi tiêu biểu	14 ngày
12	Thực hiện bật tắt các mutator L1, L2, L3, CmpLog để xác định vai trò từng thành phần, so sánh tất cả các kết quả đạt được với baseline	14 ngày
13	Tổng hợp kết quả, viết luận văn, đóng gói mã nguồn, script và dữ liệu	7 ngày
	Bảo vệ	

4. Cán bộ hướng dẫn:

1. Các bộ hướng dẫn chính:

Họ và tên: Lê Đình Thanh

Chức danh khoa học: Tiến sĩ

Cơ quan công tác: Đại học Công nghệ - ĐHQGHN

Email: thanhld@vnu.edu.vn

2. Cán bộ đồng hướng dẫn:

Họ và tên: Nguyễn Đại Thọ

Chức danh khoa học: Tiến sĩ

Cơ quan công tác: Đại học Công nghệ - ĐHQGHN

Email: nguyendaitho@vnu.edu.vn

- Ý kiến nhận xét, đánh giá của cán bộ hướng dẫn:

(ký và ghi rõ họ, tên)

.....

.....

.....

.....

- Xác nhận của Bộ môn:

(ký và ghi rõ họ tên)

.....

.....

.....

.....

Hà Nội, ngày tháng năm 2025

Học viên

(Ký và ghi rõ họ tên)